

AmasCar Gitleaks 機密掃描報告

全專案 Git 歷史機密掃描

掃描日期：2026-10-02（掃描時間 2026-10-02 17:25:45 (UTC+8)） 掃描工具：Gitleaks

掃描設定：.gitleaks.toml（gitleaks 內建規則庫 + 專案 allowlist） 掃描範圍：19 條分支（本機 6 / 遠端 19） / 556 個 commit

遠端同步：2026-10-02 17:25:33 (UTC+8)（本機上次 git fetch origin 的時間；此後遠端若有新增分支不在本次掃描範圍內）

19
掃描分支數（去重）

556
檢查 commit 數

1
潛在洩漏風險（finding）

Medium-High
整體風險等級

一、執行摘要

本次針對本機與遠端全部 19 條分支（556 個 commit）的歷史進行機密掃描，發現 1 筆私鑰類 finding：GCP 服務帳戶金鑰檔 `config/google_api_secret.json`。目前所有分支的最新版本都不含此檔案（已於 2026-04-20 移除），但引入它的 commit 仍留在遠端分支 `feat/reserve` 的歷史中，未進入 `develop`、`main` 等其他分支。整體風險暫定 Medium-High，需要有權限的人員確認此金鑰是否已在 GCP 撤銷。

其中 13 條分支僅存在遠端（本機沒有對應分支）：`demo/#4924`、`develop`、`feat/admin_usage`、`feat/car_management`、`feat/fuel_record`、`feat/mileage_validation_and_etag_updates/#4924`、`feat/permissions_add_mainten_mail/#4924`、`feat/reserve`、`feat/system_setup_and_login`、`feat/user_guide`、`hotfix/image-upload/#4910`、`release2.1.0`、`test/mileage_etag_permissions_add_unit_test/#4924`

二、風險明細與資安分析

Finding 1（Medium-High）：`config/google_api_secret.json`

項目	內容
洩漏內容	RuleID：private-key / entropy：6.001951 / 檔案： <code>config/google_api_secret.json</code> ，行號 5 服務識別：amas...ve@rail...07.iam.gserviceaccount.com（GCP 服務帳戶金鑰，依檔案 type 欄位為 service_account 判斷；識別資訊已遮蔽）
進入歷史	日期：2026-04-16 11:07:56 (UTC+8) commit 碼： <code>59448f32</code> 作者： <code>kl990899 <kl990899@amastek.com></code> 描述： <code>feat: 借還、google calendaer、mail notify maintain</code>
移除時間	日期：2026-04-20 15:26:19 (UTC+8) commit 碼： <code>0da8d2d7</code> 作者： <code>kl990899 <kl990899@amastek.com></code> 描述： <code>fix: 優化格式</code> （此 commit 同時修改 7 個檔案，訊息未提及移除金鑰）
目前風險	存在於以下分支： <code>remotes/origin/feat/reserve</code> ；是否已確認在遠端：是（本機看得到的 <code>remotes/origin/*</code> 分支中包含引入此金鑰的 commit，此結果僅反映本機上次同步遠端的狀態即 2026-10-02 17:25:33 (UTC+8)，不保證是遠端當下即時狀態；分支名稱以本機快照為準，若該分支在 GitHub 上已刪除，遠端曝露判定應下修）。此 commit 未出現在 <code>develop</code> 、 <code>main</code> 、 <code>release2.1.0</code> 等其他分支。
建議處理做法	1. 立即層面：這是 GCP 服務帳戶金鑰（服務帳戶： <code>amas...ve@rail...07.iam.gserviceaccount.com</code> ），請有權限的人員至 GCP Console → 「IAM 與管理」→ 「服務帳戶」找到該帳戶，撤銷 / 刪除對應的金鑰，並視情況輪替為新金鑰 2. git 歷史層面：該 commit 目前只存在於 <code>remotes/origin/feat/reserve</code> 的歷史中，如需徹底清除，可用 <code>git filter-repo</code> 或 BFG 改寫該分支歷史；因為沒有進入主線，改寫範圍僅限這一條分支。這仍屬於改寫歷史的操作，需要強制推送、且有此分支的協作者要重建本機分支；若該分支已不再使用，也可評估直接刪除遠端分支。本報告僅提出建議，實際是否執行、由誰執行需使用者自行決定與操作

評估維度	客觀依據 / 資安標準	本案實測狀況	對風險等級的影響
洩漏類型（CWE）	CWE-798（Use of Hard-coded Credentials） CWE-321（Use of Hard-coded Cryptographic Key）	RuleID：private-key，依 RuleID 判斷為私鑰類	基礎分類偏高危（憑證 / 金鑰直接寫入版控）

可利用性 (Exploitability)	CVSS：Attack Vector	<code>confirmed_on_remote = true</code> ，存在於 <code>remotes/origin/feat/reserve</code>	Attack Vector: Network，任何有此 repo 讀取權限者皆可直接從歷史取得，可利用性「高」
防護性 / 存續性 (Exposure)	CVSS：Scope / Remediation Level	<code>tracked_now = false</code> ，2026-04-20 已從現行程式碼移除，目前所有分支的最新版本都不含此檔案	非直接曝露於當前最新程式碼，但歷史未清理，防護性「部分改善」
資訊熵 (Entropy)	Gitleaks Rule Detection	entropy： <code>6.001951</code>	偏高熵，高機率為真實機密；是否為仍有效的金鑰需由有權限的人員確認

綜合評定：**Medium–High**。依「已同步遠端 × 已移除僅存於歷史」對應到矩陣中的 Medium–High 區間。實際風險是否等同 High，取決於這把金鑰是否已在 GCP Console 撤銷 / 輪替——這一點無法從 git 歷史掃描判斷，需要人工確認；已撤銷則可降為 Low（僅剩 git 歷史規範問題），未撤銷則等同 High。